

Web Application Penetration Testing Report

Target Application : OWASP Juice Shop

Project : Web Application Penetration Testing

Prepared By : Deva Priya

Date : 04 July 2026

Table of Contents

1. Executive Summary	3
2. Scope	3
3. Objectives	4
4. Methodology	4
5. Tools Used	5
6. Findings Summary	6
7. Detailed Findings	7
7.1 Login Admin	7
7.2 DOM XSS	9
7.3 Reset Jim Password	10
7.4 Forgotten Developer Backup	12
7.5 Poison Null Byte	14
7.6 Five-Star Feedback	16
7.7 Error Handling	18
7.8 Privacy Policy	19
8. Conclusion	21
9. References	22

EXECUTIVE SUMMARY

A manual web application penetration test was conducted on the OWASP Juice Shop application to identify common web security vulnerabilities. The assessment focused on authentication, authorization, input validation, sensitive data exposure, and security misconfigurations. Testing was performed using Burp Suite Professional and Kali Linux within a controlled lab environment. Eight findings were successfully identified and verified. Appropriate remediation recommendations have been included for each issue.

SCOPE

Item	Description
Target	OWASP Juice Shop
Environment	Local Docker Deployment
Methodology	Manual Penetration Testing
Standards	OWASP Testing Guide

OBJECTIVES

The objectives of this assessment were:

- Identify web application vulnerabilities.
- Assess authentication mechanisms.
- Evaluate authorization controls.
- Test input validation.
- Identify sensitive information exposure.
- Recommend remediation strategies.

METHODOLOGY

Reconnaissance

- Explored application features.
- Identified available endpoints.
- Reviewed user functionality.

Proxy Configuration

- Configured Firefox to use Burp Suite.

- Captured HTTP requests.
- Modified requests where necessary.

Vulnerability Testing

- Authentication
- Access Control
- Input Validation
- Sensitive Data Exposure
- Security Misconfiguration

TOOLS USED

Tool	Purpose
Kali Linux	Testing Platform
Burp Suite Professional	HTTP Proxy
Firefox	Browser
OWASP Juice Shop	Target Application

FINDINGS SUMMARY

Finding	Risk	Status
Login Admin	Critical	Verified
DOM XSS	High	Verified
Reset Jim Password	High	Verified
Forgotten Developer Backup	High	Verified
Five-Star Feedback	Medium	Verified
Poison Null Byte	Medium	Verified
Error Handling	Low	Verified
Privacy Policy	Informational	Verified

DETAILED FINDINGS

1. Login Admin

Severity

Critical

OWASP Category

Injection / Broken Authentication

Description

The assessment demonstrated that the application permits administrative authentication through an intentionally vulnerable mechanism. Successful exploitation results in privileged access to administrative functionality.

Impact

- Administrative account compromise
- Unauthorized access to sensitive data
- Potential privilege escalation
- Increased attack surface

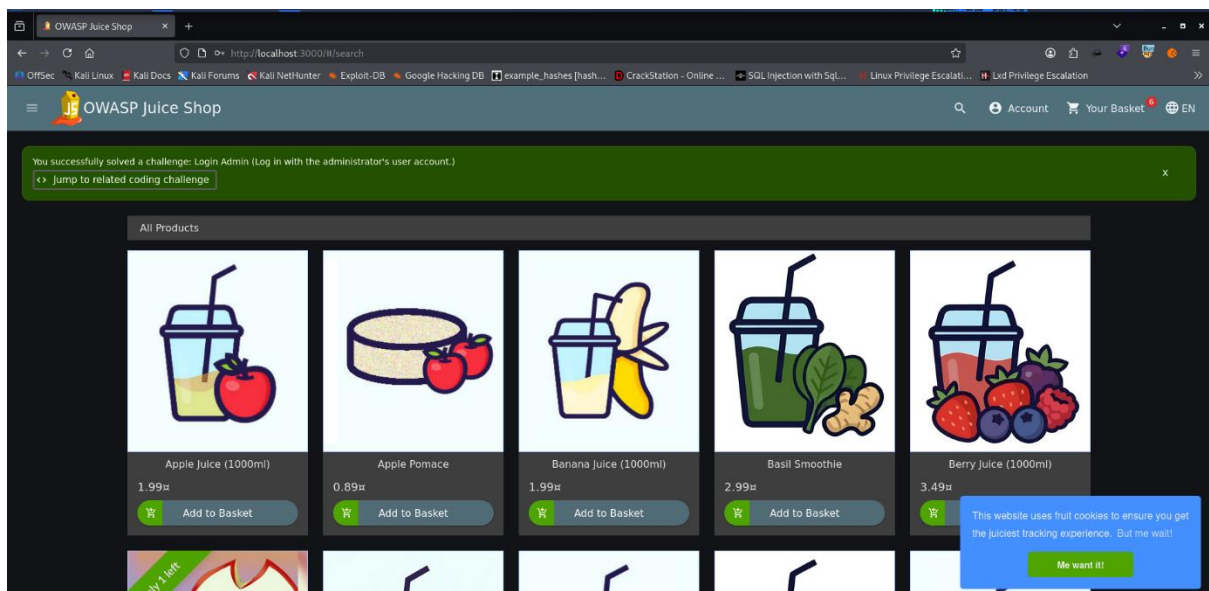
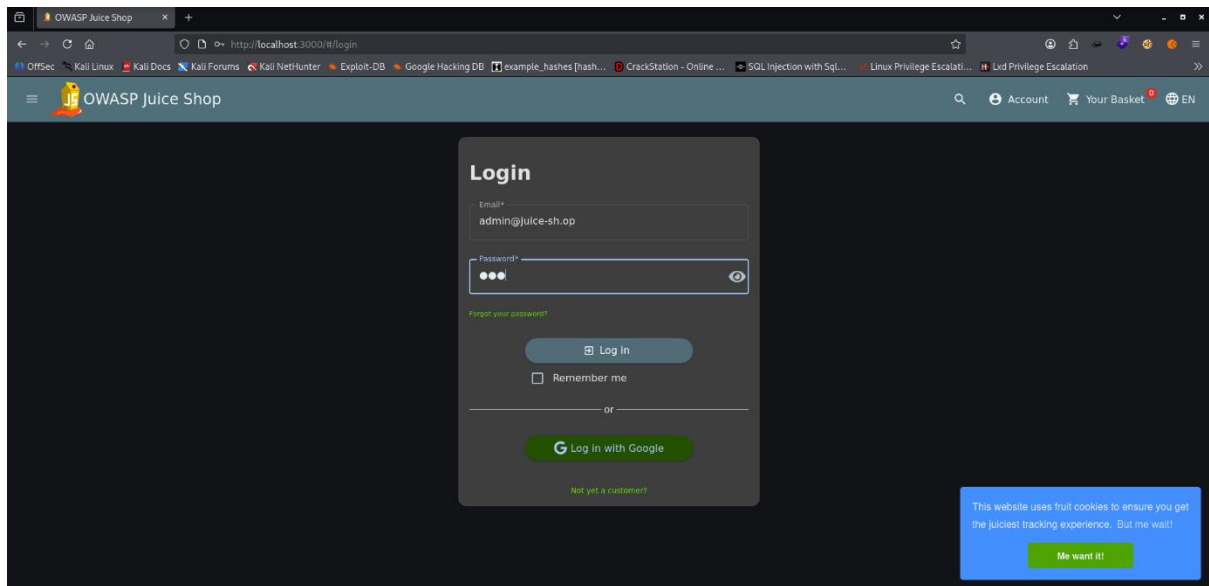


Fig:2 Successful completion of the "Login Admin" challenge.

Recommendation

- Implement parameterized queries.
- Enforce secure authentication.
- Enable multi-factor authentication.
- Validate user credentials securely.

2. DOM XSS

Severity

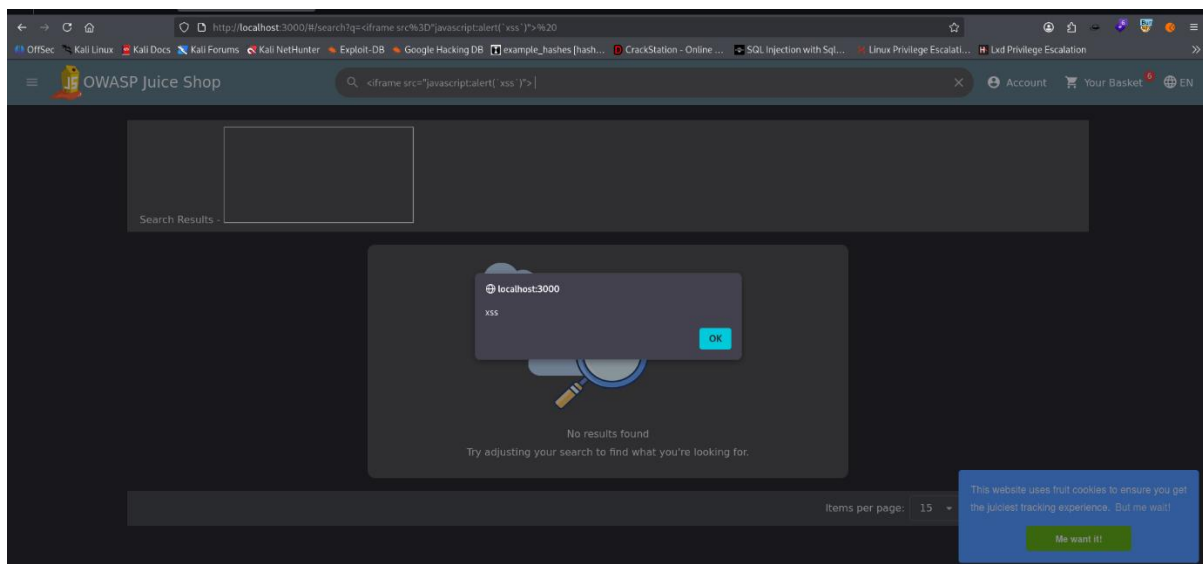
High

Description

A DOM-based Cross-Site Scripting vulnerability was identified. The application executes client-side JavaScript based on improperly handled user input.

Impact

- JavaScript execution
- Session hijacking
- Credential theft
- Website defacement



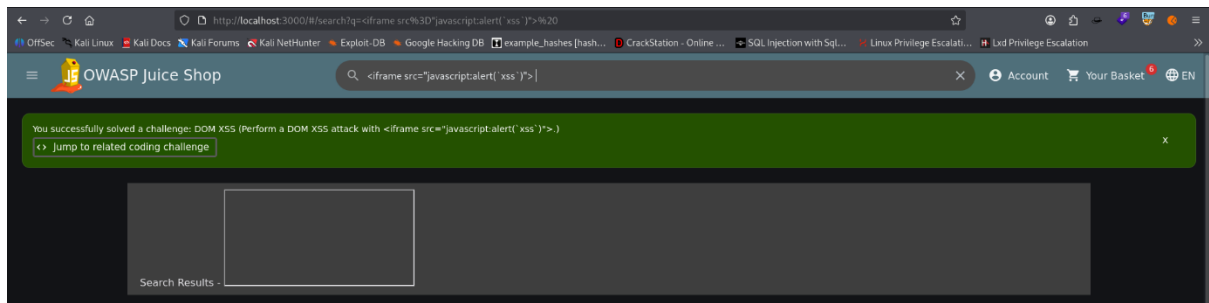


Fig:4 Successful DOM XSS demonstration.:4

Recommendation

- Use token-based password reset mechanisms.
- Enforce multi-factor authentication.
- Avoid static security questions.

3. Reset Jim Password

Severity

High

Description

The password recovery functionality relies on weak security questions, allowing unauthorized password reset when predictable answers are known.

Impact

- Account takeover
- Credential compromise
- Unauthorized access

OWASP Juice Shop

AccountYour BasketEN

Invalid email or password.

Email*

jim@juice-sh.op

Password*

Forgot your password?

Log In

Remember me

or

Log in with Google

Not yet a customer?

This website uses fruit cookies to ensure you get the juiciest tracking experience. But me wait!

Me want it!

Family

George Samuel Kirk Sr.
(father)
Winona Kirk (mother)
George Samuel Kirk Jr.
(brother)
Tiberius Kirk
(grandfather)
James (maternal
grandfather)
Aurelan Kirk (sister-in-
law)
Peter Kirk (nephew)
2 other nephews

OWASP Juice Shop

AccountYour BasketEN

Forgot Password

Email*

jim@juice-sh.op

Security Question*

New Password*

Password must be 5-40 characters long. 6/20

Repeat New Password*

6/20

Show password advice

Change

This website uses fruit cookies to ensure you get the juiciest tracking experience. But me wait!

Me want it!

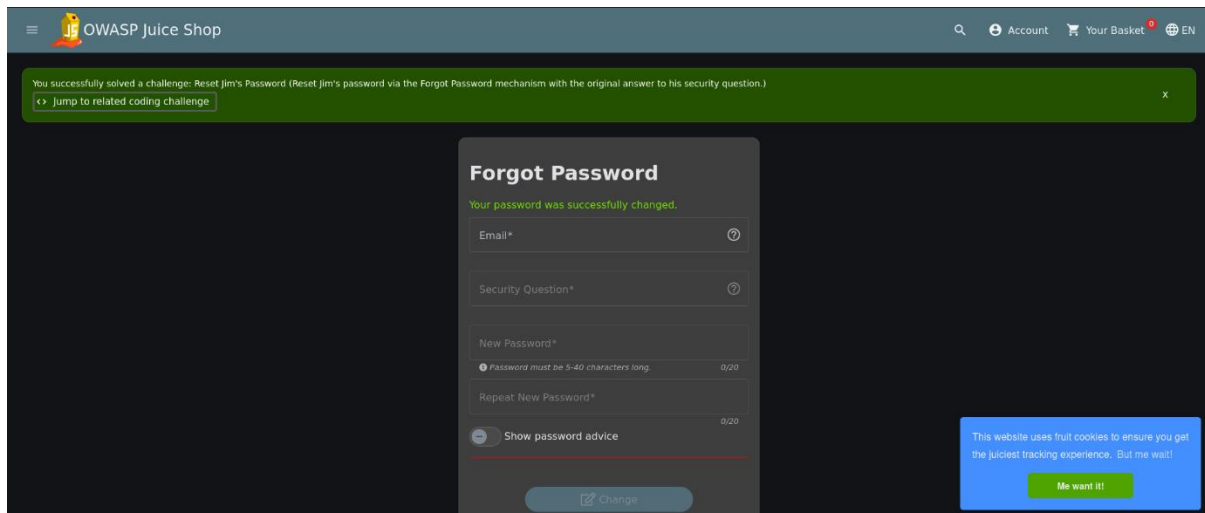


Fig:8 Password successfully reset.

Recommendation

- Use token-based password reset mechanisms.
- Enforce multi-factor authentication.
- Avoid static security questions.

4. Forgotten Developer Backup

Severity

High

OWASP Category

A05:2021 – Security Misconfiguration

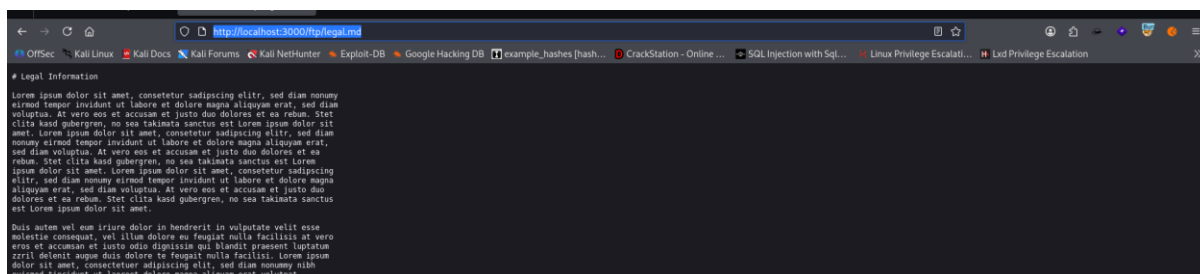
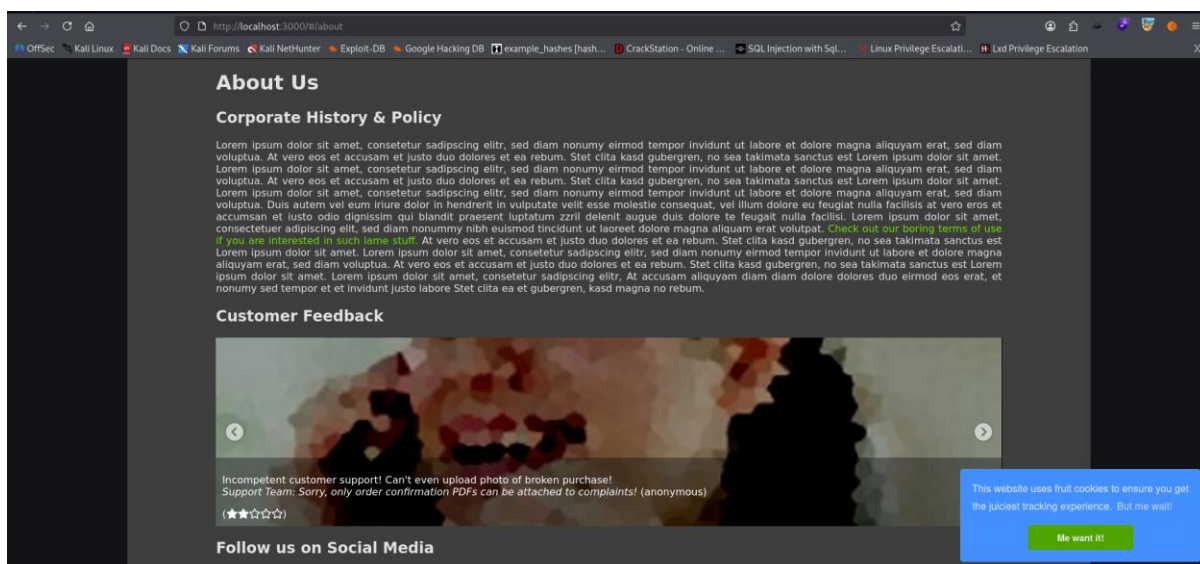
Description

During the assessment, a backup file containing application resources was discovered. Such files are often unintentionally left on publicly accessible servers during development or deployment. If exposed, backup

files may reveal sensitive information such as source code, configuration files, credentials, or internal application logic.

Impact

- Exposure of sensitive application data
- Disclosure of source code or configuration files
- Increased likelihood of further attacks
- Leakage of credentials or API keys



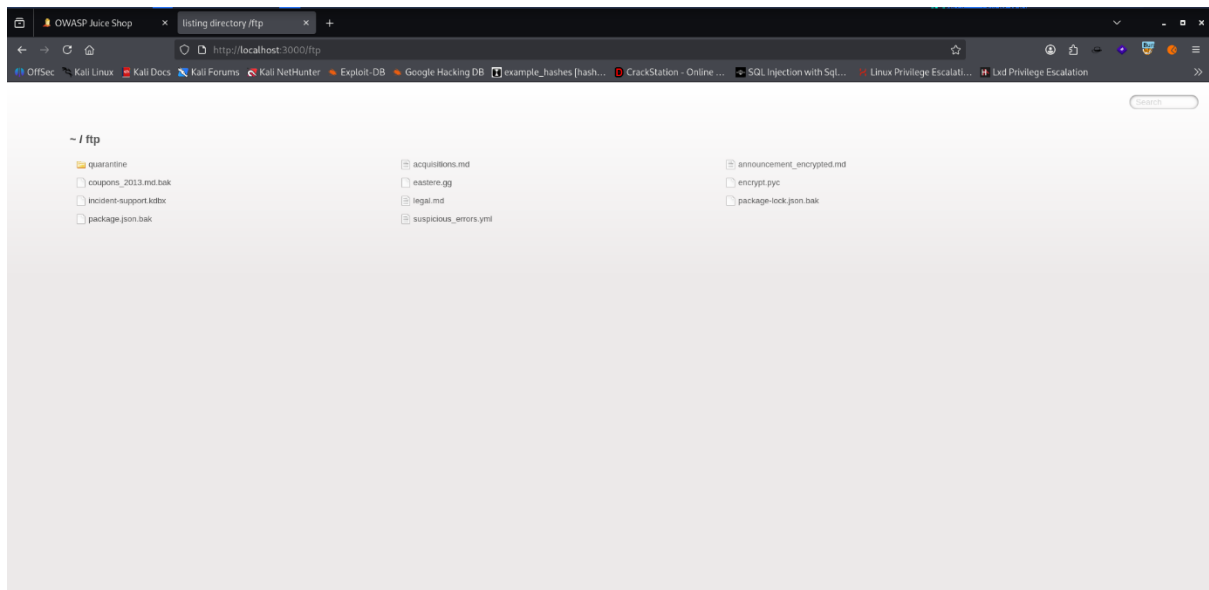


Fig:11 Discovery of an exposed developer backup file.

Recommendation

- Remove unnecessary backup files from production environments.
- Restrict access to sensitive directories.
- Perform regular security reviews before deployment.
- Implement automated checks to detect exposed files.

5. Poison Null Byte

Severity

Medium

OWASP Category

A03:2021 – Injection

Description

The assessment demonstrated a Poison Null Byte attack, where a null byte character is used to manipulate application input handling. In vulnerable applications, improper validation of file names or paths may allow attackers to bypass intended restrictions or influence file processing behavior.

Impact

- Potential file access bypass
- Unauthorized access to application resources
- Circumvention of validation controls
- Increased risk of local file inclusion in vulnerable applications

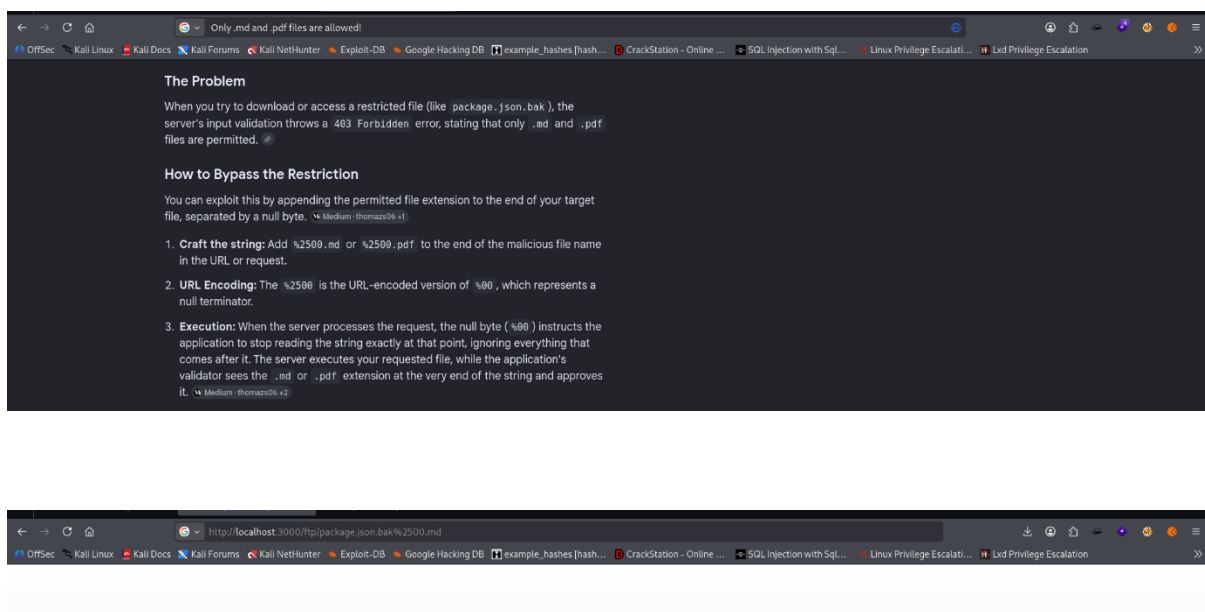


Fig:13 Successful completion of the Poison Null Byte challenge.

Recommendation

- Validate and sanitize all user-supplied input.
- Use secure file handling mechanisms.
- Avoid relying solely on filename extensions for validation.
- Apply allow-list validation for permitted file types.

6. Five-Star Feedback

Severity

Medium

OWASP Category

A01:2021 – Broken Access Control

Description

The assessment demonstrated that application functionality related to user feedback could be manipulated beyond the intended behavior. Weak access controls or insufficient validation of user actions can allow unauthorized modification of application data.

Impact

- Manipulation of application content
- Loss of data integrity

- Unauthorized modification of user-generated information
- Reduced trust in application functionality

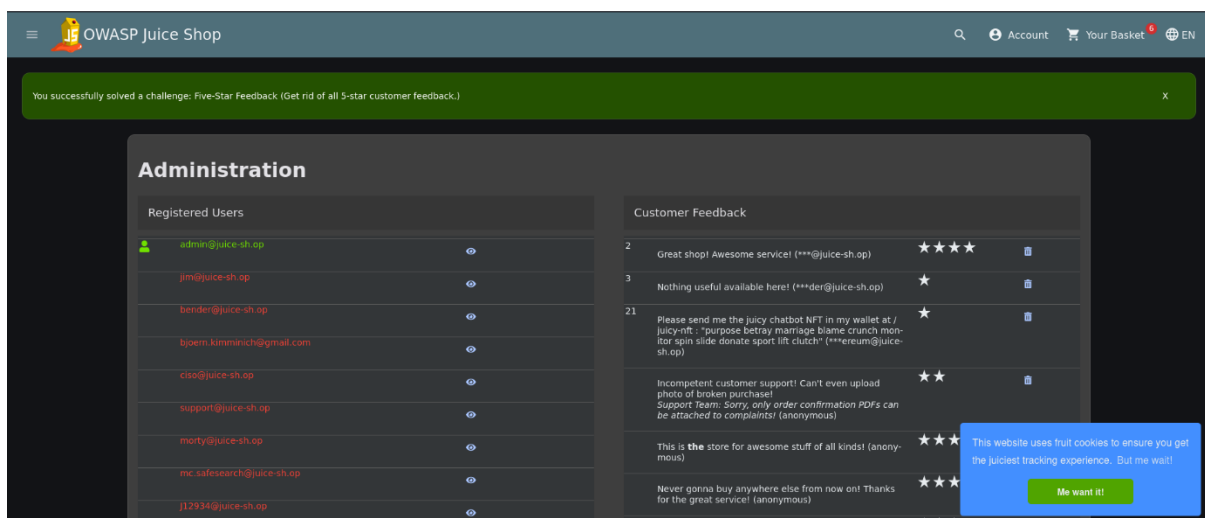
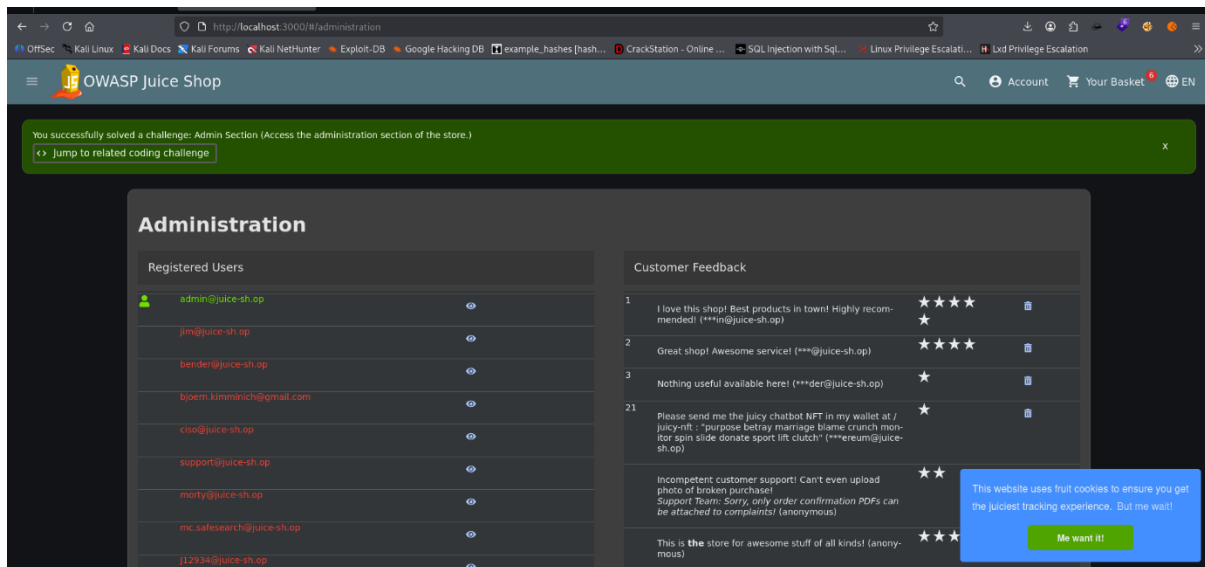


Fig:15 Successful manipulation of the feedback submission.

Recommendation

- Enforce server-side validation of user actions.
- Verify user permissions before processing requests.

- Implement robust access control mechanisms.
- Validate all user-supplied data on the server.

7. Error Handling

Severity

Low

OWASP Category

A05:2021 – Security Misconfiguration

Description

The application generated verbose error messages during testing. Detailed error responses can reveal information about the application's internal implementation, framework, or configuration, which may assist attackers during reconnaissance.

Impact

- Information disclosure
- Easier reconnaissance for attackers
- Increased understanding of application architecture
- Potential assistance in identifying additional vulnerabilities

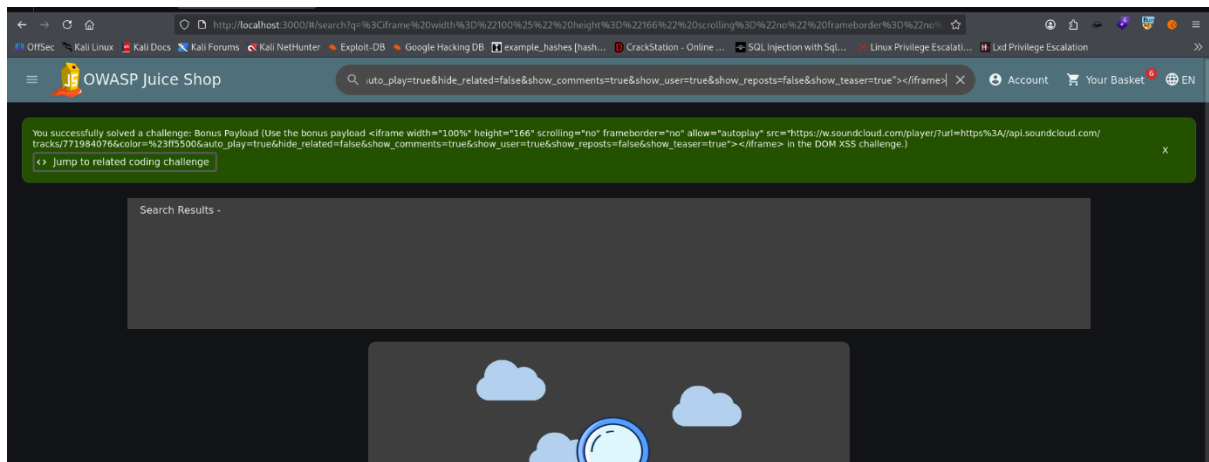


Fig:16 Application response displaying detailed error information.

Recommendation

- Display generic error messages to users.
- Log detailed exceptions only on the server.
- Disable debugging features in production.
- Review error handling mechanisms during development.

8. Privacy Policy

Severity

Informational

OWASP Category

Best Practice / Information Disclosure Review

Description

The privacy policy was reviewed as part of the application assessment. This activity verifies whether security- and privacy-related information is appropriately

presented to users and whether unnecessary sensitive information is disclosed through public documentation.

Impact

- No direct security vulnerability identified
- Supports compliance and transparency
- Highlights the importance of clear privacy communication

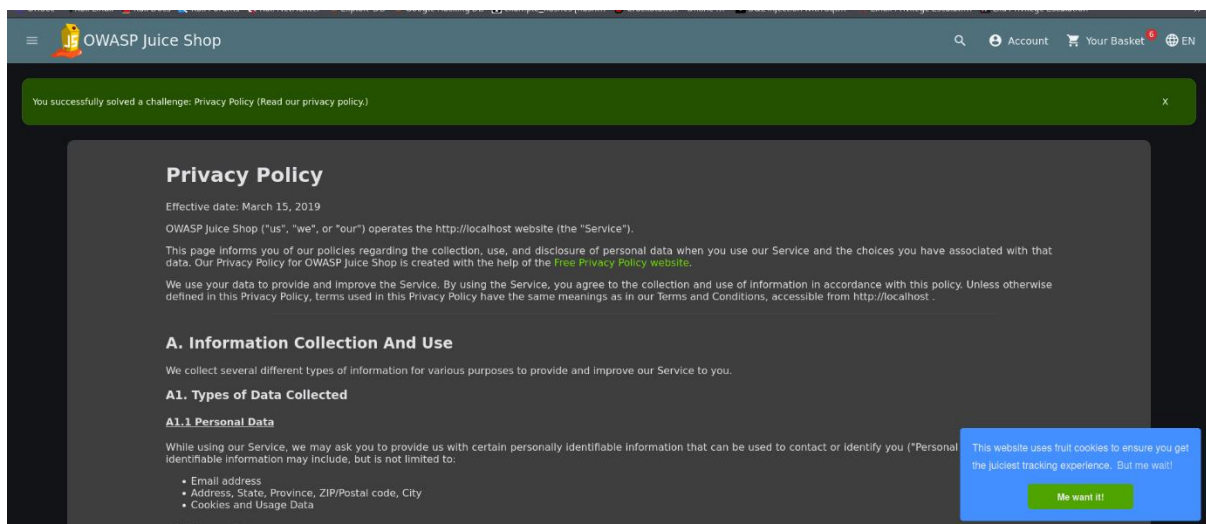


Fig:17 Successful completion of the Privacy Policy review challenge.

Recommendation

- Keep privacy policies accurate and up to date.
- Avoid disclosing unnecessary implementation details.
- Ensure compliance with applicable privacy regulations.
- Review documentation regularly as the application evolves.

CONCLUSION

The penetration test identified multiple vulnerabilities affecting authentication, access control, input validation, and sensitive information exposure. While OWASP Juice Shop is intentionally vulnerable for educational purposes, the assessment highlights common weaknesses that may also be found in real-world web applications. Applying secure coding practices, robust authentication mechanisms, and proper input validation would significantly reduce the application's attack surface.

REFERENCES

- [OWASP Top 10:2025](#)
- OWASP Testing Guide
- Burp Suite Documentation
- OWASP Juice Shop Documentation